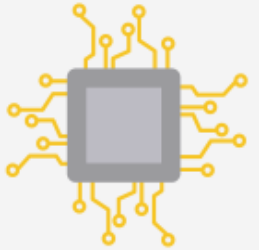

بِسْمِ اللَّهِ الرَّحْمَٰنِ الرَّحِيمِ

خوش آمدید





سناریو



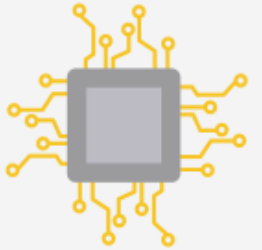
توی این سناریو، ما یه گوشی اندروید داریم که روش **NetHunter** نصب شده.

این گوشی نقش یه **Bad USB**رو بازی می‌کنه.

وقتی به سیستم هدف وصل بشه، در سریع ترین زمان ممکن، یه فایل **keylogger**رو دانلود می‌کنه، اونو توی استارتاپ قرار میده و بعد از هر ریستارت، کیلاگر هم کار خدش رو انجام میده و کیلاگ ها رو به سرور مهاجم می‌فرسته.



انواع USB

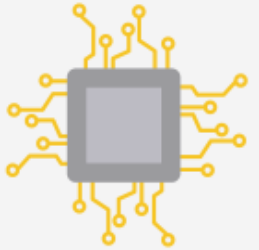


usb: یه ابزار ساده برای انتقال فایل که ساده‌ترین نوع محسوب میشود با این حال باز هم می توان حمله های قدیمی را با این usbانجام داد مثل اتو رانر یا ransomwares.

usb killer: این یکی اصلاً به فکر دزدیدن اطلاعات نیست. **USB Killer**یه سخت‌افزار مخربه که وقتی وصل می‌شه، ولتاژ خیلی بالایی رو از پورت **USB** می‌گیره و ظرف چند ثانیه خازن‌ها رو پر می‌کنه بعد تخلیه می‌کنه توی مدار. نتیجه؟ سوختن مادربورد و از بین رفتن کل سیستم. یه حمله فیزیکی محض برای نابود کردن سخت‌افزار



Bad USB



اینجا بحث جذاب شروع می‌شه. **Bad USB** از لحاظ فیزیکی شبیه یه فلش مموری هست. ولی درواقع یه میکروکنترلر هست که خودش رو به سیستم به عنوان یه کیبورد معرفی می‌کنه. سیستم فکر می‌کنه یکی داره با کیبورد تایپ می‌کنه، در حالی که این دستگاه داره دستورات از پیش نوشته شده رو با سرعت خیلی بالا تایپ می‌کنه. دیگه هیچ آنتی‌ویروسی نمی‌تونه جلوش رو بگیره چون سیستم داره دستورات یه کاربر واقعی رو اجرا می‌کنه.»



انواع Bad USB

از نظر روش حمله، **Bad USB**ها به چند دسته تقسیم می‌شن:

- **Ducky Script**: ساده‌ترین روش، شبیه ماکروی کیبورد
- **HID Payload Injection**: تزریق مستقیم دستورات به سیستم عامل
- **USB MITM**: نشستن بین کیبورد واقعی و سیستم و شنود تمام تایپ‌ها
- **Phantom Keystrokes**: تایپ کردن دستورات توی پس‌زمینه بدون نشون دادن چیزی به کاربر

امروز ما از روش اول یعنی **Ducky Script**توی **NetHunter**استفاده می‌کنیم»



NetHunter

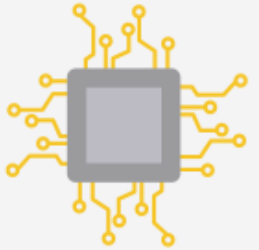
NetHunterدر واقع یه پلتفرم تست نفوذ موبایل هست که توسط تیم (**Offensive Security** همون تیم پشت **Kali Linux**) ساخته شده. این پلتفرم روی گوشی‌های اندرویدی نصب می‌شه و اونها رو تبدیل می‌کنه به یه دستگاه هکینگ قابل حمل.

چیزی که **NetHunter**رو خاص می‌کنه اینه که فقط یه لانچر ساده نیست. یه محیط کامل **Kali Linux**هست که توی گوشی اجرا می‌شه با همه ابزارهایی که از **Kali**انتظار داریم: **Metasploit**، **Nmap**، **Wireshark**، **Aircrack-ng**و صدها ابزار دیگه. همه اینها توی جیب شما جا می‌گیرن.

در کنار این، **NetHunter**یه اپ استور مخصوص داره با ده ها اپ امنیتی، یه ابزار به اسم **USB Arsenal**برای کنترل حملات **USB**، و قابلیت **KeX**که بهتون اجازه میده محیط کامل دسکتاپ **Kali**رو روی صفحه گوشی یا مانیتور خارجی ببینید.»



نسخه های NetHunter



Feature	NetHunter Rootless	NetHunter Lite	NetHunter
App Store	Yes	Yes	Yes
Kali cli	Yes	Yes	Yes
All Kali packages	Yes	Yes	Yes
KeX	Yes	Yes	Yes
Metasploit w/o DB	Yes	Yes	Yes
Metasploit with DB	No	Yes	Yes
NetHunter App	No	Yes	Yes
Requires Root	No	Yes	Yes
Wi-Fi Injection	No	No	Yes
HID attacks	No	No	Yes
BT Arsenal	No	No	Yes
CARsenal	No	No	Yes



NetHunter Pro

تفاوتش چیه؟ **NetHunter** معمولی مثل این می‌مونه که اندروید رو داشته باشی و بعد روش یه **Kali Linux** نصب کنی. اما **NetHunter Pro** مثل اینه که کل اندروید رو پاک کنی و مستقیم **Kali Linux** رو روی گوشی بوت کنی.

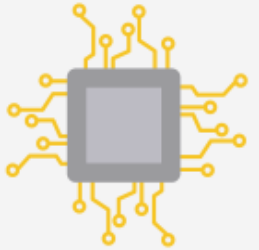
نتیجه چی میشه؟ دسترسی کامل به همه ابزارهای **Kali Desktop**، قابلیت اتصال به مانیتور خارجی با **HDMI**، و مهمتر از همه هیچ محدودیتی از سمت اندروید نداری.

الان این نسخه روی دستگاه‌های خاصی مثل **OnePlus 6**، **Poco F1** و **PinePhone** کار می‌کنه.

چیزی که **NetHunter Pro** رو خاص می‌کنه اینه که شما دیگه با یه گوشی موبایل معمولی طرف نیستید. با یه لپ‌تاپ کوچک ۵ اینچی طرفید که توی جیبتان جا می‌شه و می‌تونه هر کاری که یه **Kali Linux** دسکتاپ می‌کنه، انجام بده.»



Key logger



Keyloggerدقیقاً چیه؟ دستگاهی - چه نرم‌افزاری چه سخت‌افزاری - که همه چیزهایی را که شما تایپ می‌کنید، ضبط می‌کند. رمز ایمیل، پسورد شبکه‌های اجتماعی، شماره کارت بانکی، پیام‌های خصوصی - هر چیزی.

دو نوع اصلی داریم: نرم‌افزاری که روی سیستم نصب می‌شه، و سخت‌افزاری که فیزیکی بین کیبورد و کامپیوتر قرار می‌گیره. توی سناریوی ما از نوع نرم‌افزاری استفاده می‌کنیم.

کی‌لاگری که ما داریم استفاده می‌کنیم با پایتون نوشته شده. وقتی روی سیستم هدف اجرا بشه، هر کلیدی رو توی یه فایل ذخیره می‌کنه و بعد اون فایل رو به سرور ما می‌فرسته. چون ما کی‌لاگر رو توی استارتاپ قرار می‌دیم، حتی اگه کاربر سیستم رو ریستارت کنه، باز هم کی‌لاگر اجرا می‌شه و به کارش ادامه می‌ده.

خطرناکترین قابلیت کی‌لاگرها اینه که کاملاً مخفی می‌تونن باشن. نه پنجره‌ای باز می‌کنن، نه صدایی دارن، نه توی تسک‌بار دیده می‌شن. فقط ساکت و آروم نشستن پشت سیستم و هر چی تایپ می‌کنید رو می‌فرستن برای مهاجم.



ممنون از توجهتون